

**ENTI**Escola de Noves
Tecnologies InteractivesUNIVERSITAT DE
BARCELONA

“Conclusions i propostes a futur- Tatami Honeypot”

Autor:

Martí Tarrasón, Lluç Galceran, Roger Vallés, Ian Nogueira

Assignatura:

Anàlisi i Disseny d'Algorismes Avançats

Curs:

Ciberseguretat, 2025-2026

Data d'entrega:

Barcelona, 28/05/2026

1. Evolució de V1 a V2: millores implementades

La transició de la primera versió (V1) a la segona iteració (V2) del sistema Tatami Honeypot ha estat guiada per l'objectiu de minimitzar el deute tècnic, desacoblar la lògica de control dels fluxos de dades i dotar la plataforma d'una capacitat d'expansió autònoma i adaptativa davant les accions de l'adversari.

1.1 Arquitectura dinàmica basada en fitxers de configuració (CSV)

La limitació fonamental de la versió V1 residia en el seu caràcter estàtic, atès que l'arbre de decisions de la línia de comandes presentava un alt acoblament amb el codi font:

Definició de fases: Totes les instàncies i els estats del graf estaven definits directament de forma estàtica (hardcoded) dins del fitxer `grafo.py`.

Lògica de transició: Les condicions i rutes d'avançament estaven lligades de manera unívoca a les definicions de les classes bàsiques.

Detecció d'atacs: Els patrons de cerca s'emmagatzemaven com a llistes immutables dins del mòdul `patrons.py`.

Aquest disseny implicava que qualsevol modificació del comportament o de la base de coneixement de l'entorn requerís una reestructuració i edició directa del codi en Python.

La versió V2 resol aquesta problemàtica mitjançant la transició cap a una arquitectura dinàmica conduïda per dades, on l'estructura i el coneixement del sistema es deleguen completament a un conjunt de fitxers estructurats en format CSV:

fases.csv: Actua com a repositori dels nodes del graf, definint dinàmicament la identitat i el nivell de risc de cada fase.

transicions.csv: Conté el mapeig de les aristes de la màquina d'estats, associant cadenes d'entrada amb canvis de context.

patrons.csv: Emmagatzema de forma externa les seqüències d'atac que l'autòmat ha de monitorar.

bbdd_comandos.csv: Estableix una base de dades de referència exhaustiva amb més de 860 registres de comandes del sistema operatiu i eines ofensives de tercers.

Impacte arquitectònic: S'aconsegueix una abstracció total de la configuració respecte a l'execució. El honeypot esdevé parametrizable sense necessitat de modificar el codi font.

1.2 Mecanisme d'enriquiment automàtic del graf

Esdevé una de les principals aportacions de la versió V2, dissenyada per dotar el sistema de resiliència i expansió dinàmica durant una sessió activa d'auditoria o atac.

Quan un adversari executa una comanda que no disposa d'una implementació simulada explícita en el honeypot, el flux de control és interceptat per la classe d'excepció "ComandoNoEncontrado". En lloc de limitar-se a emetre un missatge d'error estàndard, el sistema inicia un procés de cerca indexada dins del repositori global "bbdd_comandos.csv".

Flux de processament:

1. **Intercepció:** L'atacant introdueix una instrucció específica no simulada (per exemple: `nmap -sV 192.168.1.1`).
2. **Cerca d'instrucció:** La classe de gestió de comandes no reconegudes valida la presència de la comanda dins del diccionari de la base de dades en memòria.
3. **Actualització del graf:** Si la cerca és reeixida, s'invoca el mètode `enriquecer()` del mòdul `enriquecedor.py`, el qual realitza de forma immediata dues operacions d'escriptura persistents:
 - S'afegeix de forma dinàmica una nova ruta de transició a `transicions.csv`.
 - Es registra el patró maliciós associat dins del fitxer `patrons.csv`.
4. **Sincronització:** El monitor dinàmic de seguretat reflecteix el canvi d'estat i el nou vector de risc en el següent cicle d'avaluació.

Anàlisi de complexitat temporal: Aquesta operació presenta una complexitat de cost constant, $O(1)$, atès que la base de dades de referència es troba completament indexada i carregada com a estructura de taula de dispersió en memòria permanent des de l'encesa del sistema.

Benefici operatiu: El sistema posseeix una capacitat de creixement orgànic i indefinit en temps d'execució (runtime) sense requerir cap reinici de la shell. Permet recopilar informació rellevant i mapar les intencions de l'atacant fins i tot davant d'eines que la plataforma no sap simular detalladament.

1.3 Monitorització dinàmica de fluxos

La visualització i el control forense de la plataforma s'han redissenyat per complet per adaptar-se al paradigma determinat per les dades externes.

En la versió V1, la inferència de la fase actual es realitzava mitjançant la inspecció d'un llistat rígid de paraules clau estenografiades (hardcoded). En contrast, el monitor de la versió V2 implementa un bucle de refresc iteratiu amb una freqüència de cicle de 2 segons, encarregat de rellegir i processar de forma autònoma les estructures de transicions.csv i fases.csv.

Complexitat algorísmica: El cost computacional del procés de detecció en cada refresc es defineix com a $O(t)$, on t representa el nombre total de transicions registrades de manera dinàmica en el graf.

Sincronització en temps real: Aquest disseny garanteix que qualsevol mutació provocada pel mecanisme de l'enriquidor automàtic sigui assimilada pel component de visualització de forma instantània, oferint una traçabilitat forense exacta del nivell de compromís de la sessió.

1.4 Taxonomia de la Base de Dades de Referència

La fortalesa predictiva i de classificació del sistema es recolza sobre l'estructura de "bbdd_comandos.csv", la qual cataloga més de 860 directrius reals utilitzades en entorns d'auditoria i intrusió. Cada registre es troba normalitzat i parametritzat sota els següents vectors d'informació:

Identificador d'instrucció: El nom canònic del binari o utilitat.

Estat d'origen: La fase mínima requerida de la màquina d'estats per validar el context (escala de 0 a 5).

Estat de destí: La fase d'escalada a la qual transiciona el graf un cop detectada la interacció (escala de 1 a 5).

Tàctica / Patró ATT&CK: L'associació directa amb la taxonomia del framework de seguretat MITRE ATT&CK.

Impacte forense: Gràcies a aquest catàleg extens, el perímetre operatiu del honeypot ja no es troba limitat de manera estricta als 45 binaris implementats de manera simulada a la shell. El programari adquireix la capacitat de reconèixer el context operacional de centenars d'eines professionals, registrant la traça de l'atac de manera coherent amb els estàndards de la indústria.

2. Limitacions de la implementació actual (V2)

Malgrat els avenços estructurals introduïts en la segona versió, s'han identificat determinats vectors de vulnerabilitat procedimental i lògica que limiten l'eficàcia del sistema en entorns de producció reals.

2.1 Simulació pura i manca d'execució real

Descripció de la limitació: Les instruccions processades i integrades mitjançant el mòdul d'enriquiment automàtic no s'executen en un entorn operatiu real; el sistema es limita a registrar la intenció i retornar de manera sistemàtica un error d'execució de tipus `command not found`.

Impacte operatiu: Un analista o atacant experimentat pot detectar fàcilment el caràcter simulat del honeypot (fingerprinting) en observar que les comandes formalment validades a la base de dades "bbdd_comandos.csv" no despleguen el comportament sintàctic ni els fluxos de sortida habituals. Així mateix, la manca d'indicadors de sortida (outputs) autèntics redueix dràsticament el valor forense de la sessió.

Exemple:

```
ubuntu@ubuntu-server:~$ nmap -sV 192.168.1.1
```

```
bash: nmap: command not found
```

Contex: El sistema ha registrat la transició i ha elevat el nivell de risc en el graf, però l'adversari rep un missatge d'error genèric que delata la manca de servei real.

2.2 Rigidesa en la Detecció de Patrons (Falta d'Aprenentatge)

Descripció de la limitació: L'heurística del sistema es troba restringida a un catàleg discret de 14 patrons d'atac fixos.

Impacte operatiu: L'arquitectura actual és incapaç de reconèixer variants o mutacions d'un mateix vector d'atac (per exemple, l'establiment d'una reverse shell executada mitjançant intèrprets de Perl, Ruby o binaris alternatius en lloc de Bash o Python). En no disposar d'un motor d'aprenentatge automàtic (Machine Learning), les regles de correlació romanen estàtiques, impeding la detecció d'amenaces persistents avançades (APT) no catalogades prèviament.



2.3 Absència d'anàlisi de conducció temporal

Descripció de la limitació: El motor de processament actual avalua les comandes com a esdeveniments aïllats en una seqüència, ignorant els intervals cronològics i les variables de temps entre interaccions.

Impacte operatiu: La plataforma no pot computar mètriques crítiques com la velocitat d'execució (essencial per diferenciar un atacant humà d'un script automatitzat o un bot), intervals de pausa sospitosos, ràfegues de força bruta o bucles cíclics de reintent (retry loops).

Estudi comparatiu de vectors temporals:

Operador humà: Introducció de comandes seqüencials amb pauses de reflexió o lectura d'outputs ($\Delta t \approx 2 \text{ s}$). * Agent automatitzat (Bot/Script): Execució concatenada de comandes en una sola línia de temps ($\Delta t < 0.1 \text{ s}$):

```
ubuntu@ubuntu-server:~$ whoami; id; uname; ps aux | grep sudo
```

Manca de detecció: La versió V2 processa ambdues interaccions de manera idèntica, perdent la capacitat de categoritzar la naturalesa de l'adversari.

2.4 Aïllament logístic

Descripció de la limitació: El registre d'activitat es genera exclusivament de manera local en fitxers plans text (/archivos/LOGn.log).

Impacte operatiu: La manca d'exportació mitjançant protocols estàndard (com Syslog) cap a sistemes de gestió d'esdeveniments i informació de seguretat (SIEM) com Wazuh, Splunk o la pila ELK impedeix la centralització de dades. Això fa impossible correlacionar esdeveniments de manera distribuïda o detectar campanyes d'intrusió coordinades que afectin múltiples honeypots simultàniament.

3. Propostes de desenvolupament futur

Per tal de mitigar les limitacions descrites, es proposa una ruta de desenvolupament incremental dividida segons l'impacte potencial i el cost d'implementació estimat.

3.1 Execució confinada en entorn en una *Sandbox*

Objectiu: Dotar les comandes enriquides dinàmicament de funcionalitat real i outputs autèntics, incrementant el dwell time (temps de permanència) de l'atacant.

Metodologia d'implementació: Integració del mòdul subprocess en conjunció amb mecanismes de control de recursos del sistema operatiu (resource) i filtres de crides al sistema (seccomp). Es proposa la creació d'una classe de confinament que limiti de manera estricta el temps de CPU, la memòria virtual assignada i la capacitat de bifurcació de processos (forking), forçant l'execució sota un identificador d'usuari sense privilegis (uid 1000).

Beneficis: Obtenció d'indicadors de compromís (IoC) i respostes 100% realistes que mantenen el valor forense sense exposar el sistema amfitrió (host).

3.2 Motor de detecció d'anomalies v3

Objectiu: Transicionar d'un model de detecció basat en signatures fixes a un model heurístic capaç de reconèixer mutacions de vectors d'atac.

Metodologia d'implementació: Desplegament de l'algorisme no supervisat Isolation Forest. El sistema vectoritzarà les comandes en temps d'execució transformant el text en atributs numèrics (mètrica de longitud de cadena, densitat de canonades | i ràtio de paraules clau d'alt risc com sudo, chmod o nc).

Mapeig de comportaments per a l'entrenament del model:

Perfil normal: Interaccions estàndard de gestió de fitxers i navegació (ls, pwd, cat file.txt, grep).

Perfil d'tac: Procediments d'enumeració de privilegis, descàrrega de scripts o obertura de sockets negatius (find / -perm -4000, wget http://... | bash, base64 -d | nc).

3.3 Mòdul d'Anàlisi Cronològica i Temporal

Objectiu: Classificar la naturalesa de l'amenaça (humana o automatitzada) mitjançant l'estudi de perfils de comportament en el temps.

Metodologia d'implementació: Desenvolupament d'un analitzador que calculi les derivades temporals (Δt) entre esdeveniments, identificant patrons automatitzats quan la mitjana d'interval sigui inferior a un llindar crític ($\Delta t < 0.5$ s). Així mateix, s'establiran finestres lliscants per alertar sobre atacs de força bruta si es computa un nombre d'errors de llicència superior a N intents en un bloc de T segons.

3.4 Emulació de respostes sintètiques de baix cost

Objectiu: Oferir una alternativa intermèdia i segura abans del desplegament del sandbox real.

Metodologia d'implementació: Desenvolupament d'una estructura de casos especials dins del gestor d'enriquiment que intercepti binaris comuns (com nmap o nc) i retorni capçaleres simulades d'aspecte legítim en lloc de l'error del sistema operatiu. Evita el risc d'execució real amb un cost computacional negligible.

3.5 Matriu comparativa de millores proposades

Vector de millora	Prioritat	Complexitat / Esforç	Impacte Operatiu
Confinament en sandbox real	Alta	Mitjana	Molt Alt
Model ML (Isolation forest)	Alta	Alt	Molt Alt
Anàlisi de flux temporal	Mitjana	Mitjana	Alt
Outputs sintètics simulats	Mitjana	Baix	Mitjà
Integració SIEM (Wazuh)	Baixa	Baix	Mitjà

4. Conclusions operatives y veredictes

4.1 Assoliments consolidats de la versió V2

Desacoblament de l'arquitectura: La transició cap a una estructura Data-Driven mitjançant fitxers CSV permet la mutabilitat del sistema sense necessitat de recompilació o alteració del codi font.

Expansió dinàmica del perímetre: El mecanisme d'enriquiment automàtic eleva de manera orgànica el rang del honeypot, estenent el reconeixement des dels 45 binaris base de la V1 fins a més de 860 directrius complexes.

Traçabilitat en temps real: L'algorisme de refresc del monitor garanteix la sincronització i categorització de l'estat de risc en un interval màxim de 2 segons.

Rigor dissenyat en POO: L'aplicació correcta del polimorfisme i l'herència a través de la classe abstracta ComandoHoneypot dona solidesa a la base del programari.

4.2 Restriccions tècniques de la V2

L'estat actual del codi presenta fronteres definides: requereix l'adopció d'arquitectures basades en subprocessos aïllats per assolir un realisme complet, l'ús de models matemàtics probabilístics per identificar noves amenaces i la sortida cap a sockets de xarxa distribuïts per operar en entorns corporatius corporatius.

4.3 Veredictes final i àmbits d'aplicació

Àmbit acadèmic / educatiu: El sistema demostra de manera òptima la viabilitat pràctica de conceptes avançats de l'enginyeria de programari: programació orientada a objectes, disseny algorísmic, estructures de grafs de decisió i recursió eficient sota historials mitigats.

Àmbit operatiu: Per al seu desplegament en una xarxa corporativa real, es requereix formalitzar la transició cap a la Versió 3 (V3), implementant el confinament real en sandbox, la detecció predictiva via Machine Learning i la centralització d'alertes en un gestor d'esdeveniments SIEM.

La línia evolutiva del projecte ratifica que Tatami Honeypot s'ha consolidat com una arquitectura modular d'alta flexibilitat, preparada per incrementar la seva complexitat defensiva sense requerir una refactorització estructural del seu nucli operatiu.